ISSN 1229-800X [Print] / ISSN 2586-7792 [Online]
The Transactions of the Korean Institute of Electrical Engineers, vol. 69P, no. 4, pp. 267~274, 2020
https://doi.org/10.5370/KIEEP.2020.69.4.267

An Implementation of User Authentication System using Keystroke Dynamics-based and Adaptive Risk-based Authentication

키스트로크 다이나믹스 및 적응형 위험 기반 인증방식을 활용한 사용자 인증 시스템 구현

Ji-Ahn Shin · Sang-Hyeop Lee · Seung-Hyeon Lee · Il-Hyn Lee · Kwangjae Lee
신지안* · 이상협* · 이승현* · 이일현* · 이광재†

Abstract

In this paper, we propose a system that has the convenience of single-factor authentication and security of multi-factor authentication at the same time. This system consists of keystroke dynamics-based authentication(KDA), which uses biometrics, and adaptive risk-based authentication(A-RBA), which uses a user access information. KDA applied the One-Class SVM model, which is an unsupervised learning method that uses small dataset, and A-RBA applied the KNN model, which is supervised learning through a dataset created as a virtual scenario. As a result of the experiment, FAR and FRR of KDA are 0.21 and 0.04, respectively, and accuracy, recall, precision, F1 score, and CVAA of A-RBA are 97.5%, 98.5%, 98.3%, 98.1% and 99.2%, respectively. This result is higher performance than other machine learning models such as Logistic Regression and SVM. This proposed system not only provides user convenience, but will also be a good way to overcome the increasingly emerging hacking attacks.

Key Words

User authentication, Adaptive risk-based authentication, Keystroke dynamics-based authentication, Machine learning

1. 서 론

웹서비스에서 가장 많이 사용되는 인증방식은 사용자 비밀번호 인증으로 사용자들이 편리하다고 생각하는 방식이지만, 보안성이 다소 떨어진다. 그 이유는 사용자들이 여러 사이트에서 같은 아이디와 비밀번호를 사용한다는 것이다. 이 경우, 취약한 사이트로부터 유출된 계정정보를 무작위로 대입해 탈취하는 크리덴셜 스터핑 공격에 매우 취약하다[1]. IT업체 Akamai의 2020년 인터넷 및 보안 금융 서비스 공격 보고서에 따르면, 2019년 8월 단일 규모로는 가장 큰 약 5500만회의 크리덴셜 스터핑 공격이 있었다[2]. 이와 같이 현재에도 2개 이상의 사이트에서 동일한 아이디와 패스워드를 사용하게 된다면 계정 탈취의 위험이 있다.

사용자의 인증 방법으로는 지식 기반, 소유 기반, 존재 기반, 행위 기반 인증으로 나뉜다. 지식 기반 인증은 사용자의 특정 지식을 확인하여 사용자를 인증하는 기법으로 패스워드 인증이 있다. 소유 기반 인증은 사용자가 가지고 있는 것을 확인함으로써 인증하는 기법으로 PIN과 One-Time Password(OTP) 인증이 있다. 존재 기반 인증은 흔히 생체인증이라고 하며, 사용자의 음성, 지문 인식, 얼굴 인식 등이 있다. 행위 기반 인증은 사용자의 불편을 최소화하기 위해 사람의 자각없이 일정 시간 동안의 행동을 확인하여 인증하는 기법으로 키보드 입력, 음성, 걸음걸이, 심전도 뇌파 등을 확인하는 방식이 있다[3]. 또한, 인증방식 사용 수에 따라 Single-Factor Authentication(SFA)와 Multi-Factor Authentication(MFA)로 나뉜다. SFA는 사용자의 인증 방법을 한 가지만 사용하는 방식으로, 웹서비스에서 많이 사용한다. 이 방식은 매우 편리하지만 보안성이 낮다는 단점이 있다. 최근 이러한 우려를 반영하여 사용자 인증 방법 중 두 가지 이상 사용하는 방식인 MFA를 사용하는 서비스를 지원하고 있다. MFA는 패스워드 인증 외에도 OTP, PIN, 지문 인식 등 다양한 방식을 지원한다[4]. 플랫폼마다 MFA에 사용하는 인증방식 종류 차이가 발생하는데, 휴대기기의 경우 지문, 얼굴 인식, 단말기 고유정보를 통해 비교적 쉽고 다양한 인증 방법을 제공한다. 그러나 웹 서비스의 경우, MFA에 사용하는 인증하는 방법이 한정되어있다. 이런 방식들은 사용자가 불편함을 초래하는데, 일례로 2018년 구글에서 Gmail 계정

† Corresponding Author : Dept. of Information Security Engineering, Sangmyung University, Korea.
E-mail: begleam@smu.ac.kr
https://orcid.org/0000-0003-2832-6347
* Dept. of Information Security Engineering, Sangmyung University, Korea.
Received : October 20, 2020 **Revised :** November 24, 2020 **Accepted :** November 26, 2020

Copyright ⓒ The Korean Institute of Electrical Engineers
This is an Open-Access article distributed under the terms of the Creative Commons Attribution Non-Commercial License (http://creativecommons.org/licenses/by-nc/4.0/)which permits unrestricted non-commercial use, distribution, and reproduction in any medium, provided the original work is properly cited.
This paper was nominated for the best paper at 2020 Summer Conference of the Korean Institute of Electrical Engineers, and it was approved and published by the Editorial Committee after review of the electrical society.

을 대상으로 조사를 하였는데 이용자 중 로그인 시 2차 인증 방식으로써 OTP를 사용하는 비율이 총 이용자의 10% 미만이라는 결과가 나왔다[5]. 보안성이 아무리 중요해도 편리하지 않다면 사용자들은 MFA 인증방식을 사용하지 않는다는 것을 알 수 있다. 이러한 이유로 웹에서 편리성과 보안성을 고려한 인증 방법으로 위험 기반 인증(Risk-Based Authent ication; RBA) 방식이 제안되었다. RBA 방식은 인증 요청 시 IP주소, 접속 위치 등을 이용해 사용자의 인지 없이 백그라운드에서 위험판단을 하는 방식으로, 구글, 아마존, 링크드인, 굿올드게임즈에서 사용하는 방식이다. IP 주소, 지리적 위치, 사용자 에이전트 문자열(운영체제, 브라우저), 시간대, 언어, 해상도 등이 예측과 다를 경우, 현재의 인증 시도의 위험성을 경보하거나 2차 인증을 요구한다[5-6].

본 논문에서는 보안성이 높고 사용자가 불편함을 느끼지 않도록 하는 무인지 접근 방식들을 활용하는 인증 시스템을 제안한다. 먼저 패스워드 인증방식에 무인지 접근 방식인 키스트로크 다이나믹스 기반 생체인증(Keystroke Dynamics-based Authent ication; KDA)을 결합하였다. 추가로, 사용자 접속정보를 확인하여 위험정도를 판단하는 적응형 RBA 방식을 수행한다. 이 과정을 통해 인증 시도의 위험성이 발생할 때만 2차 인증을 요구한다. 이를 통해, 사용자의 편의성을 보장하면서도, 기존 RBA 방식보다 높은 보안성을 갖는 인증 시스템을 제안한다.

2. 본 론

본 시스템은 웹 서버, 머신러닝 서버, 내장 데이터베이스로 구성된다. 웹 서버에서는 로그인을 통해 사용자가 접속하는 기기의 IP, 운영체제, 해상도, 웹 브라우저 정보들과 해당 국가와 도시, 시간대 및 생체 입력 패턴을 수집한다. 이러한 수집한 정보들을 통해 머신러닝 서버는 KDA 단계와 A-RBA 단계로 사용자를 확인한다. KDA 단계는 사용자의 행동 역학인 키스트로크 다이나믹스 생체입력 패턴을 통해 사용자 본인인지 판단한다. 사용자는 초기 10회의 로그인 시도를 통해 타이핑 패턴을 입력하고, 웹 및 머신러닝 서버에서 생체 입력 데이터를 수집 및 분류한다. 수집된 10회의 패턴과 로그인 시 생성된 패턴의 속도와 간격의 평균을 통해 고주파수, 저주파수 영역으로 분류한다. 분류된 두 특성을 각각 비지도 머신러닝 모델인 One-Class SVM을 통해 분류하여 군집된 범위에서 벗어난 이상치를 감지한다. 고주파수, 저주파수 두 영역 중 하나라도 이상치가 발생된다면 사용자 본인이 아닌 것으로 판단하여 2차 인증을 수행해야 한다. KDA 단계가 인증에 성공하면 A-RBA 단계로 넘어가게 된다. A-RBA는 사용자의 접속한 환경정보를 이용하여 위험 평가한다. 로그인 시 수집된 사용자 환경 정보(IP, 운영체제, 브라우저, 해상도, 국가, 도시, 시간대)를 데이터베이스에 저장된다. 그리고 로그인 성공 시 접속정보가 갱신 또는 추가된다. 이러한 과정을 통해 축적된 사용자들의 데이터로 머신러닝 모델을 학습시킨다. 사용자 본인의 정보는 1, 타 사용자 정보는 0으로 라벨의 값을 지정하여 학습한다. 학습된 모델을 통해 로그인 시 사용자 접속 환경정보로 사용자 본인 판단 시 로그인을 진행, 본인이 아닐 시 2차 인증을 수행해야 한다.

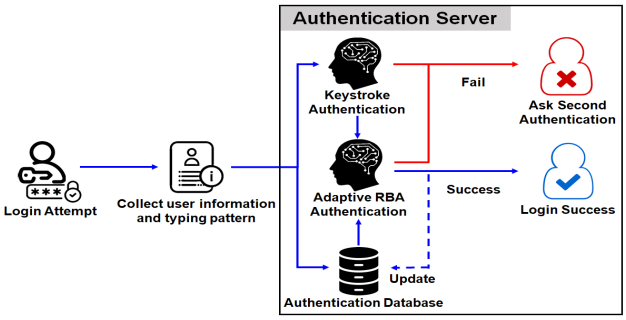

그림 1 제안하는 인증 시스템의 블록도
Fig. 1 A block diagram of the proposed authentication system.

2.1 머신러닝 알고리즘

머신러닝의 알고리즘은 훈련데이터(training data)에 종속 변인(label)이 있는 상태에서 컴퓨터를 학습시키는 지도학습 방식과 훈련데이터에 종속 변인 없이 컴퓨터에 학습시키는 비지도 학습 방식 두 경우로 구분한다. 지도학습 방식은 크게 분류(classification)와 회귀(regression) 알고리즘을 활용하여 개발한다. 분류는 데이터를 카테고리에 따라 분류하는 방법이고, 회귀는 연속적인 값을 예측해 내는 방법이다. 비지도 학습 방식은 유사한 데이터들을 찾아서 모으는 군집화(clustering)나 차원이 큰 데이터를 축소하여 특징들을 찾아내는 차원 축소 같은 알고리즘들을 활용해 개발한다. 다음의 표 1은 제안하는 인증 시스템에 적용할 수 있는 머신러닝 알고리즘들의 목록이다[7].

키스트로크 다이나믹스 생체 데이터는 사람마다 타이핑 패턴 또는 속도 등이 달라 정답의 집합을 특정할 수 없다. 그래서 KDA에서는 지도학습보다는 정답없이 예측하는 비지도학습을 주로 사용하며, 사용자의 타이핑 정보를 수집하고 그 사용자의 데이터를 군집화하여 사용자를 구분한다. 하지만, 적은 데이터로 특징점을 찾을 수 없는 문제가 있어 초반 5회는 사용자의 타이핑 정보를 그대로 이용하고, 그 이후 10회까지는 KNN 알고리즘을 사용한다. 이후 KNN 모델은 비지도 학습에서 사용하는 군집의 가이드가 되어 분류한다. KNN 알고리즘은 소수의 데이터셋으로도 비교적 정확하게 분류하기 때문에 제안하는 시스템에 적합하다. 이후, 수집한 데이터의 군집을 통해 특정 사용자의 타이핑 패턴의 이상치를 판별하여 분류하기 위해 비지도 학습인 One-Class SVM을 사용하였다. One-Class SVM은 정상 데이터로만 이루어진 데이터셋으로 학습하

여 고차원의 공간에서 정상치와 이상치를 분리하는 초평면과 이상치와의 거리를 최대화하는 초평면 가중치를 찾는 알고리즘이다.

표 1 제안하는 시스템에 적용 가능한 머신러닝 알고리즘
Table 1 Machine learning algorithms applicable to the proposed system

Machine Learning	Learning Method	Algorithm
Supervised Learning	Classification	KNN(K-nearest neighbors)
		Naive Bayes
		Logistic Regression
		Decision Tree
		Support Vector Machine
		Random Forest
	Regression	Support Vector Regression
		Linear Regression
		Random Forest Regression
Unsupervised Learning	Dimensionality	PCA(Principal Component Analysis)
	Clustering	DBSCAN
		K-means
		One-Class SVM

A-RBA는 정상 사용자의 데이터셋이 정답인 구조이므로 지도 학습 방식을 선택했다. 분류를 위해, 데이터베이스에 수집된 다른 사용자의 데이터셋을 오답으로 사용하였다. 비지도 학습 방식은 정상 사용자에 대한 종속 변인이 없는 상태라면, 다른 사용자라 하더라도 같은 공간에서의 접속을 같은 사용자로 인식할 수 있다는 한계가 있어 배제하였다. 지도학습 중에서도 제안하는 시스템에 적합하다고 판단되는 KNN, 로지스틱 회귀, SVM을 선택하였다[8]. KNN 알고리즘은 사용자에 의해 정해지는 하이퍼 파라미터값인 K개의 가장 가까운 이웃을 이용하여, 훈련데이터 집합에 있는 표본 간의 유사도에 따라 표본들을 분류하는 방법이다. KNN 알고리즘 특성상 비 모수적인 방법이어서 어떤 분포이든 상관없이 사용할 수 있고, 이해하기 쉽고 직관적이다. 그리고 본 연구는 데이터가 많을수록 정확한 결과를 나타낼 수 있는데 이처럼 샘플 수가 많을 때 좋은 분류법이 KNN 알고리즘이다. 로지스틱 회귀 알고리즘은 데이터를 A와 B, 2개의 카테고리 중 하나로 분류하고자 만들어진 알고리즘이다. 모델을 훈련할 때, 우리가 예측하려는 Y의 값을 A일 확률이라 생각하고, Y값이 0.5보다 크면 A로 분류하고, 0.5보다 작으면 B라고 분류하는 방식이다. 그래서 가설에서는 독립변수(X값)인 우변은 무한대의 값을 가지고, 종속변수(Y값)인 좌변은 숫자 0~1 사이의 확률 값을 얻고자 한다. 하지만, 좌변의 값이 0보다 작아질 수도 있고, 1보다 커질 수도 있으며, 우변의 값 역시 마이너스 무한대에서 플러스 무한대의 값을 가지게 될 수 있다. 이런 문제를 다시 우변을 0~1 사이의 값으로 변환하고 좌변을 플러스 무한대로 바꾸기 위해서 Y값에 대해서 로짓(Logit) 변환을 수행해야 한다. SVM 알고리즘은 N차원의 공간을 (N-1)차원으로 나눌 수 있는 초평면을 찾는 기법으로 데이터들을 가장 적합하게 가운데로 나눌 수 있는 알고리즘이다. 본 연구에서는 다차원의 데이터가 수집되기 때문에, 비선형 SVM이 필요하다. 따라서, 차원 확장을 통해 다차원 공간으로 사상하여 분류시킬 수 있는 커널 기법을 사용해야 한다. 커널 기법에서도 여러 종류가 있는데, 본 논문에서는 다차원 데이터를 적용할 수 있는 가우시안 RBF 커널 기법을 시험해보았다.

2.2 KDA

타이핑 패턴을 이용한 KDA는 키보드를 이용하여 사용자가 Password의 각 문자를 입력할 때의 시간 차를 생체인증 패턴으로 사용하여 인증하는 방법이다[9]. 연속으로 키보드를 누르는 시간(T_{a1}, T_{b1})과 연속으로 키보드에 손을 뗄 때의 시간(T_{a2}, T_{b2})을 통해 타이핑에서 발견되는 사용자의 고유한 패턴을 얻을 수 있다. 사용자가 키보드를 누를 때 Key-Down 이벤트가 발생하고 눌렀던 키를 땠을 때 Key-Up 이벤트가 발생한다. 두 개의 키 입력 시각 값을 통해, 식 (1)-(4)와 같은 특성을 수집한다.

$$Duration = (T_{a1} - T_{a2}) \tag{1}$$

$$Interval = (T_{b1} - T_{a2}) \tag{2}$$

$$Latency_{(Up-Up)} = (T_{b2} - T_{a2}) \tag{3}$$

$$Latency_{(Down-Down)} = (T_{b1} - T_{a1}) \tag{4}$$

그림 2는 사용자가 'ABC'를 입력했을 때의 누른 시간(Key-Down)과 뗀 시간(Key-Up)이다. 이를 바탕으로 4개의 특성을 계산한다. Duration은 하나의 키의 지속시간으로 계산할 수 있다. Interval은 연속된 두 키 AB의 A를 뗀 후부터 B를 누른 시각 차이로 AB의 간격으로 계산한다. Latency는 AB 두 개 키를 눌렀을 때의 간격 또는 뗀 시각의 간격을 말한다. 사용자가 입력한 타이핑 데이터를 계산하여 나온 결과인 *Duration, Interval, Latency*$_{(Up\text{-}Up)}$, *Latency*$_{(Down\text{-}Down)}$을 기반으로 데이터셋을 생성한다. 이러한 타이핑 패턴을 패스워드 인증에 적용하여 타인이 같은 텍스트를 입력해도 타이핑 패턴의 시간이 다르다는 특징을 이용하여 사용자를 식별한다.

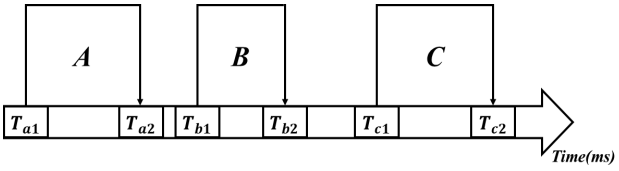

그림 2 키를 입력하는 동안 발생되는 키 이벤트
Fig. 2 The key events that occur while the user is typing a key. (Time to press the keyboard(T_{a1}, T_{b1}, T_{c1}) and time to release the keyboard(T_{a2}, T_{b2}, T_{c2}))

2.2.1 데이터셋 수집 및 전처리 과정

KDA는 과거 여러 실험이 지속 연구되어왔지만, 대부분의 실험은 중대형 데이터셋에 대한 분류에 초점을 두고 있다. 제안하는 인증 시스템에는 웹 사용자의 키스트로크 다이나믹스 생체정보를 수집하는데 큰 규모의 사용자 패턴 정보를 수집해 사용하는 것은 사용자마다 수천에서 수백만의 데이터 수집 과정이 필요하므로 중소규모의 서버에는 적용할 수 없다고 판단했다. 그래서 소형 데이터셋을 사용하여 인증하는 연구를 참고하여 다음과 같이 인증 모델의 기준을 선정하였다[10]. 첫째, 비지도 학습으로 인증한다. 둘째, 10개의 작은 데이터셋으로 모델을 학습시킨다. 즉, 제안하는 인증 시스템은 사용자가 10번의 로그인을 통해 데이터셋을 생성한다면 사용자 인증에 사용되는 인증 모델을 생성한다. 데이터셋을 생성하기 위해 10개의 사용자 타이핑 패턴 데이터를 얻어야 한다. 10번의 로그인을 시도하여 데이터를 수집할 수 있지만, 사용자가 패스워드를 일관되지 않게 입력하는 경우가 많다. 한 번은 빠르게 입력하고 다음 입력 때에는 느리게 입력할 수 있다. 사용자의 타이핑 리듬에서 발생할 수 있는 편차로 이를 해결하지 않을 시 인증 성능이 현저히 떨어지므로, 전처리를 통해 이상치(Outlier)를 제거하여 인증 성능을 향상시킨다. 즉, 수집한 10개의 샘플이 사용자의 타이핑 패턴을 나타내는지 확인해야 한다. 처음 5개의 샘플은 이상치를 탐지하기 위해 사용되는 실제 사용자 데이터로 가정한다. 처음 5개 샘플은 K-S(Kolmogorov-Smirnov) 검정을 사용하여 데이터를 검증하였다.

K-S 검정은 두 집단의 분포 유사성을 측정하는 방법으로 경험적 분포 함수 간의 최대 거리(D)를 통계량으로 사용한다[11]. 타이핑 데이터의 4개의 특성 각각을 경험적 분포 함수로 정의하고 이를 통해 K-S 통계량을 구한다. K-S 통계량은 수식 (5)-(7)로 정의할 수 있다. N_R은 참고 용도의 키스트로크 다이나믹스 패턴 정보에 포함된 입력 키간 간격(latency)의 총합이며, N_T는 검증하는 키스트로크 다이나믹스 패턴 정보에 포함된 입력 키간 간격의 총합니다. 각 누적 분포 함수 F는 다음 수식 (5)-(6)과 같다.

$$F_{K_R}(x) = \frac{1}{N_R}\sum_{i=1}^{N_R} I(X_i \le x) \tag{5}$$

$$F_{K_T}(x) = \frac{1}{N_T}\sum_{i=1}^{N_T} I(X_j \le x) \tag{6}$$

여기서, X_i, X_j는 독립 항등 분포(Independent and identically distributed random variables)를 따른다. 식 (7)은 K-S 통계량으로 두 개 데이터셋의 누적 분포 차이의 최댓값을 의미한다. 즉, 이 값이 작을수록 두 분포는 유사하다 할 수 있다.

$$D_{K_R \mid K_T} = supx \mid F_{K_R} - F_{k_T} \mid \tag{7}$$

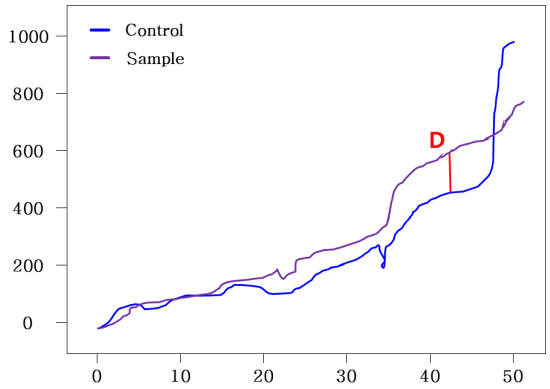

그림 3 K-S 검정의 예(제어와 샘플 경험적 분포 함수 간의 최대 거리(D)를 통계량으로 사용)

Fig. 3 An example of K-S test. The maximum distance, D, between control and sample cumulative distribution function as statistic. The x-axis is the data value and the y-axis is the cumulative probability

이를 기반으로 이후 5개의 샘플들은 처음 5개의 샘플과 유사한 경우에만 수집한다. 유사성은 KNN 알고리즘을 사용하여 판단한다. 처음 입력된 5개의 샘플들의 K번째 거리를 계산한다. 본 논문에서는 K=3을 선택한다. K=3의 거리를 계산하여 나온 거릿값들의 평균을 구한다. 이후 입력되는 데이터가 평균보다 작거나 같을 때 실제 데이터로 유사하다고 판단한다. 이를 기반으로 10개의 학습 데이터가 생성될 때까지 데이터가 수집된다.

2.2.2 머신러닝 모델 훈련 과정

사용자가 로그인하여 전처리를 통해 10개 샘플을 수집 후, 이후 로그인 시도부터 인증이 수행된다. 인증이 수행되기위해 저장된 데이터는 정규화를 통해 특성을 고주파 또는 저주파로 나누게 된다. 이 데이터는 학습에 영향을 미치지 않기 때문에 두 개의 특성으로 분류될 때만 사용된다. 학습은 비지도 학습 방식으로 진행된다. 그 이유는 지도학습 방식을 사용하기 위해서는 침입자 샘플이 필요하기 때문이다. 소수의 침입자 역할 클래스를 사용하여 학습할 수 있지만, 침입자 샘플은 본인 제외한 어떤 것이든지 될 수 있어 침입자의 타이핑 패턴을 정확하게 나타낼 수 없다. 따라서 본 논문에서는 비지도 학습인 One-Class SVM을 사용하여 학습한다.

사용자 타이핑 패턴의 식별 성능을 향상하기 위해, 데이터 특성을 타이핑 시각 간격을 고주파와 저주파로 분류한다. 같은 문자를 입력하더라도 사용자마다 문자 조합의 타이핑 속도가 다르다는 점을 착안하여 사용자 패턴을 식별에 적용하였다. 정규화에서는 Key-Up 값을 사용하여 데이터셋을 정규화한다. 먼저 첫 번째 키(Key-Up) 타이밍에 따라 모든 타이밍을 전환한다. 모든 키 타이밍을 첫 번째 타이밍과 비교하여 사용자가 늦게 입력하거나 빨리 입력했을 때 발생하는 편차를 해결한다. 다음으로 각 타이밍은 첫 번째와 마지막 타이밍까지의 총 지속시간의 비율로 변환한다. 따라서 첫 번째 키 시각 값은 0이 되고 마지막 키 시각 값은 1이 될 것이다. 그림 4는

사용자마다 문자 조합의 타이핑 속도가 다르다는 점에 대한 예시로, 같은 문자 조합을 사용자마다 10회씩 입력한 데이터를 수집하고 타이핑 비율 계산하여 그래프를 표현하였다. 여기서 입력한 문자 조합은 대문자, 소문자, 특수문자, 숫자를 이용한 'Star@@2048'이다. 그림 4에서 볼 수 있듯이, 사용자가 확실히 구별되는 고주파 또는 저주파 영역이 있다. 그래프에서 't'와 'a', '2'와 '0'의 영역을 통해 사용자 간 차이가 보이고 나머지 부분은 비슷한 것을 알 수 있다. 이 두 개의 영역에서 두 번째 사용자는 첫 번째 사용자보다 넓은 영역이 있는 것을 보인다. 이 특성을 정확히 보기 위해서, 고/저주파로 표현한 타이핑 패턴 그래프로 확인하였다. 이전의 사용자 접속 시도 데이터는 고/저주파의 두 개의 원형점으로 표현된다. 또한 접속 시도는 정상 사용자의 사각형 점으로, 비정상 사용자의 경우 삼각형 점으로 표현한다. 이때 고/저주파 두 개의 점들이 생성되게 된다. 그림 5와 같이 정상 사용자 데이터는 데이터셋과 밀집된 것을 볼 수 있다. 하지만 비정상 사용자로 설정된 타 사용자 로그인에서는 하나의 점이 군집과 달리 멀리 떨어져 있는 것을 볼 수 있다.

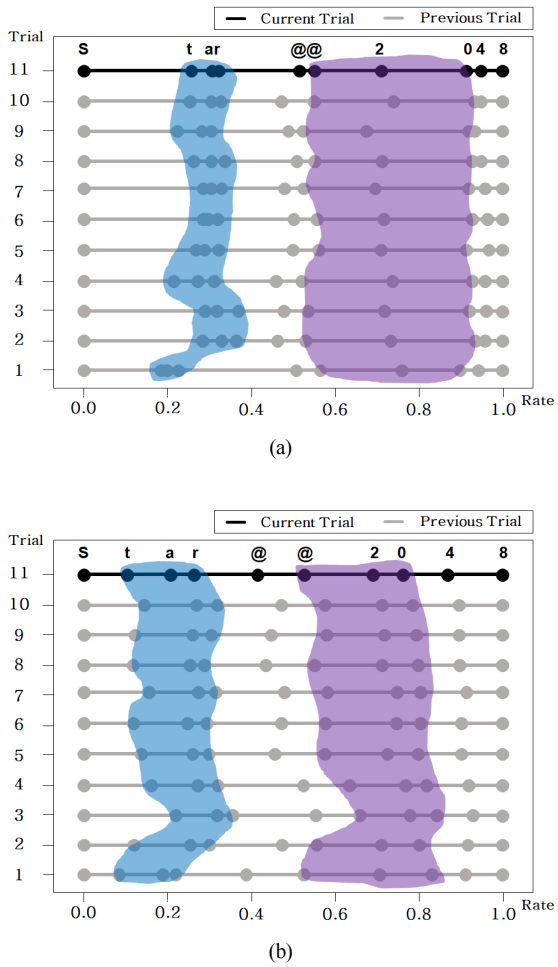

그림 4 사용자 A, B의 타이핑 패턴의 예(문자 조합 Star@2048을 각각 10회씩 입력) (a) 사용자A의 입력 패턴, (b) 사용자B의 입력 패턴

Fig. 4 Examples of user A, B's typing pattern. (String Input: 'Star@2048' typing 10 times each) (a) User A's input pattern, (b) User B's input pattern

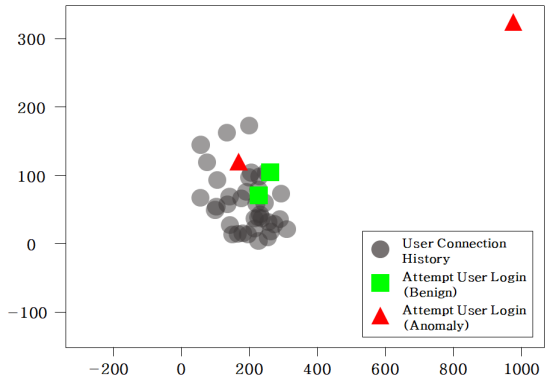

그림 5 고/저주파로 표현한 타이핑 패턴 예시(원형점: 사용자의 이전 접속 데이터, 사각형점: 정상 사용자 접속 데이터, 삼각형점: 비정상 사용자 접속데이터)

Fig. 5 Examples of typing pattern graph expressed in high/low frequency. (Circle: User Connection History, Rectangle: Attempt User Login(Benign), Triangle: Attempt User Login(Anomaly))

2.3 A-RBA

RBA는 위험 기반인증으로 위험 점수를 판단하여 위험 행동 혹은 중요한 보안 기능을 사용할 때 경고 메시지와 함께 추가 인증을 요구하는 모든 시스템이다. 머신러닝 이전의 RBA는 보안이 필요한 특정 행동이 발생하였을 경우, 사전의 정의된 행동을 위험 점수로 판단하여 추가 인증을 하는 방식이지만, 머신러닝을 적용한 A-RBA는 사용자 정보를 기반으로 분석하여 판단하는 방식이다. 대개 두 방식 모두 RBA라 부르지만 본 논문에서는 머신러닝을 사용하여 사용자 정보를 기반으로 분석하는 방식을 A-RBA로 정의한다. 머신러닝에 사용되는 로그인 이력의 요소들은 구글의 보안 경고 및 2차 인증을 요구하는 기준에 대한 요소들을 참고하여 만들었다[5]. 구글은 전에 로그인했던 정보와 현재 로그인 시도를 한 정보를 비교하여 보안 경고 메시지(로그인은 성공) 또는 2차 인증을 요구한다. 이러한 기준으로 사용되는 요소는 IP 주소, 국가, 사용자 에이전트 문자열(운영체제, 브라우저), 시간대, 언어, 해상도 등이다. 이를 참고해 본 시스템에서 사용하는 요소는 IP 주소, 국가, 도시, 운영체제, 브라우저, 해상도, 시간대이다. 시간대의 경우는 24시간 중 08~16시는 0, 17~21시는 1, 22~02시는 2, 03~07시는 3으로 나누어 값을 지정하였다[12].

2.3.1 데이터셋 수집 및 전처리 과정

본 연구에서 사용하는 로그인 정보에 정확히 부합하는 데이터셋은 존재하지 않았다. 그래서 시스템 운용에서 수집할 수 있는 정보를 통해 실험에 필요한 데이터셋을 가상으로 구성하였다. 가상 사용자는 각각 여러 시나리오를 적용하여 로그인 이력을 만들었으며 총 13명의 사용자를 만들었다. 표 2와 같이 집과 자취방을 오가며 로그인을 하는 대학생 사용자, 직장과 집을 오가며 로그인을 하는 직장인 사용자, 맥북을 사용하며 해외 출장을 다니는 회사원 사용자 등 13명의 가상 사용자를 만들었으며 로그인 이력 또한 시나리오에 맞게 30개씩 생성하였다.

표 2 가상 데이터셋 구성을 위한 사용자들의 행동 시나리오
Table 2 User behavior scenarios for constructing virtual datasets

사용자	시나리오
User A	주로 한 장소에서 접속, 2가지 브라우저 사용하며 사용 시간대가 불규칙한 사용자
User B	주중, 주말로 나눠 두 장소에서 접속, PC와 노트북을 번갈아 사용하며 사용자
User C	하루에 두 장소에서 접속, 노트북을 사용하며 사용 시간대가 규칙적인 사용자
User D	주중, 주말로 나눠 두 장소에서 접속, PC와 노트북을 번갈아 사용하며 사용자 (User B와 다른 지역)
User E	근무, 비근무로 나눠 두 장소에서 두 대의 PC로 사용하며 규칙적으로 접속하는 사용자
User F	두 장소에서 PC와 노트북을 번갈아 사용하며 사용 시간대가 불규칙한 사용자
User G	여러 장소(3개 이상)에서 서로 다른 PC를 사용하는 사용자
User H	특정 기간에 해외에서 PC나 노트북을 사용하는 사용자
User I	서로 다른 국가를 불규칙적으로 다니며 PC와 노트북을 번갈아 사용하는 사용자
User J	특정 기간에 해외에서 PC나 노트북을 사용하는 사용자(User H와 다른 OS, 다른 브라우저)
User K	특정 기간에 해외에서 PC나 노트북을 사용하는 사용자(User H와 다른 국가)
User L	주로 한 장소에서 규칙적으로 접속하며 PC나 노트북을 사용하는 사용자
User M	국가가 같은 여러 도시에서 접속하며 다른 OS를 사용하는 사용자

각 사용자의 로그인 정보가 문자열로 각각의 배열에 저장되는데 이것들을 데이터로 사용하기 위해 문자열을 숫자로 치환하여야 한다. 하지만 요소들이 모두 범주형 데이터이기 때문에 수치로 나타낼 수 없고 숫자에 1대1 대응시켜 나타내었다. 그 예시로, 사용자 A로 예상되는 사용자가 로그인에 성공하였을 때, 사용자 A를 제외한 모든 사용자(B~M) 중 9명의 사용자를 무작위로 뽑는다. 그리고 그 9명의 사용자의 데이터들을 불러와 데이터프레임 변수 Df1에 저장한다. 그 후 정답인 사용자 A의 데이터 수(로그인 이력)만큼 9명의 오답 사용자들의 데이터 수를 준비한다. 사용자 A의 데이터와 무작위로 뽑힌 오답 데이터들을 데이터프레임 변수 Df2에 저장한다. 그와 동시에 Df2에 열을 하나 더 추가하여 사용자 A의 데이터에는 참값 1로, 오답 사용자 9명의 데이터에는 거짓 값 0으로 설정한다. 그 후, 딕셔너리 변수 Dn을 생성하여 Df2에 있는 데이터들의 중복성을 제거한 후 다시 Dn에 저장한다. 즉, Dn은 'Key : Value' 형식으로 되며 각 열의 값들이 Key 값에 중복없이 저장된다. Dn에는 값들이 문자열로 들어가 있으므로 각 열에 있는 개수대로 1부터 매핑 시켜주면 데이터 전처리를 위한 매핑 정보가 완성된다.

표 3 머신러닝을 위한 사용자 정보 전처리 과정
Table 3 The pre-processing of user information for machine learning.

```
if(User A Login Success)
 tokenization()
  Variable s for digitizing strings = 1;
  Variables n to move on to the next element = 0;
   while( row.isEmpty() = false )
   do Adding User A~J Data to the Df2;
     if( Dn <- Duplication of Values)
       then Add Dn Array Without Increasing s ;
     elif(Dn <- No Duplication of Values)
       then After s = s + 1, Adding Dn Array;
  then n = n + 1, tokenization();
```

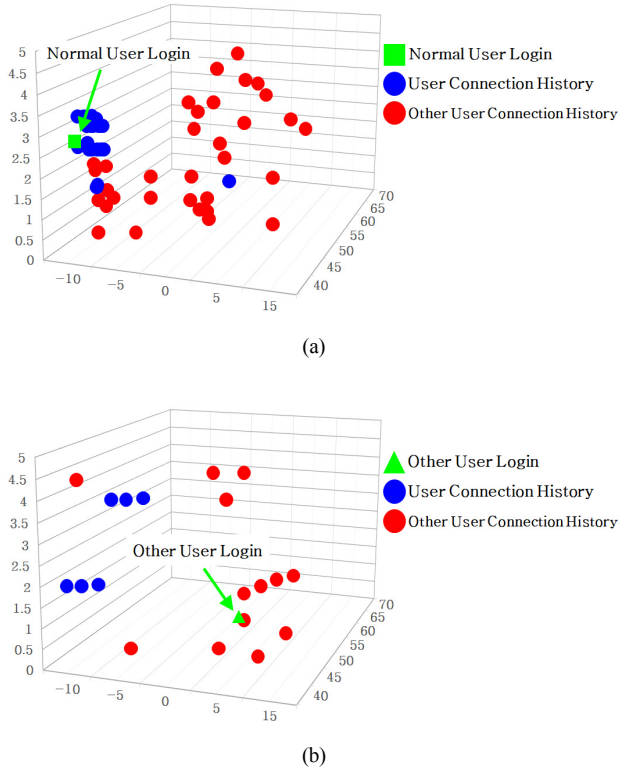

그림 6 A-RBA 데이터셋을 KNN 알고리즘으로 학습시킨 결과 그래프 예시
Fig. 6 An example graph of training A-RBA dataset with KNN algorithm

2.3.2 머신러닝 모델 훈련 과정

먼저 사용자가 로그인에 성공하면 서버에 로그인 이력이 각 사용자를 나타내는 데이터베이스에 저장된다. 만일 로그인 이력이 30개 미만일 경우는 사용자의 패턴으로 사용하기에 너무 적은 데이터이므로 머신러닝 알고리즘이 동작하지 않고 무조건 2차 인증을 요구하도록 제약 조건을 걸었다. 이후 사용자 데이터가 30개 이상 쌓이면 머신러닝 알고리즘이 동작한다. 알고리즘을 학습하기 위한 데이터로 참, 거짓 값을 1:1 비율로 사용한다. 예를 들어, 사용자A가 로그인 시도를 하며 서버에 로그인 이력이 100개 저장되어 있다고 가정한다. 사용자A의 이력 100개는 참값으로 설정한다. 그리고 사용자A를 제외한 모든 다른 사용자 중에 9명의 사용자를 랜덤하게 뽑는다. 그

9명의 사용자의 로그인 이력들 중 100개를 랜덤하게 뽑아서 거짓 값으로 설정한다. 즉, 총 200개의 사용자 데이터가 학습 및 검증 데이터셋으로 사용된다. 만약 사용자의 로그인 이력이 너무 많이 쌓이게 되면 모델이 학습하는 시간이 길어져 로그인 처리에 영향을 미칠 수 있기 때문에 최대 500개의 로그인 이력만 사용하도록 제한하며 그 이력들은 최근 500개의 이력으로 구성된다. 그림 6은 수집한 A-RBA 데이터셋을 KNN 알고리즘에 학습시켜 그래프로 나타낸 결과이다. 데이터셋이 7개의 요소로 이루어져 있어 본래는 7차원이지만 시각적인 그래프로 나타내기 위하여 3차원으로 축소해 나타내었다. 초록색 점은 정상 사용자 로그인 및 타 사용자 로그인, 파란색 점은 사용자 접속 기록, 붉은색 점은 타 사용자 접속 기록이다. 그림 6(a)처럼 초록색 점이 파란색 점과 겹친다면 정상 사용자의 로그인 그래프이고, 그림 6(b)처럼 초록색 점이 붉은색 점과 겹치거나 근처에 생긴다면 타 사용자의 로그인 그래프이다. 정상 사용자 로그인 경우는 로그인 성공으로 판단하고, 타 사용자의 로그인 경우는 2차 인증을 요구한다.

3. 실험 결과 및 평가

본 논문에서는 KDA 단계와 A-RBA단계, 두 과정으로 나눠 로그인 성공/실패를 결정하는 시스템으로, 두 과정의 예측 결과를 받은 후에 종합하여 최종 결과를 도출한다. KDA 단계와 A-RBA 단계 중 한 부분이라도 실패일 경우 타 사용자의 로그인 시도로 판단하여 2차 인증을 요구하고, 둘 다 성공일 경우에만 정상 사용자로 판단하여 로그인에 성공할 수 있다. 각 단계의 머신러닝의 성능 평가를 위해 부정허용률(False acceptance rate; FAR), 부정거부율(False rejection rate; FRR), 정확도(Accuracy), 재현율(Recall), 정밀도(Precision), F1 Score, 교차검증 정확도 평균(Cross Validation Accuracy Average; CVAA)를 사용했다[13].

3.1 KDA 평가

KDA 단계의 머신러닝 모델을 평가하기 위해 사용자 9명과 그 중 한 명을 침입자로 가정하여 데이터를 수집하였다. 각 사용자들은 10번의 로그인을 통해 타이핑 패턴를 수집하여 사용자 인증을 수행했다. 생성된 데이터셋은 고주파와 저주파 두 개의 특성으로 나누고 두 개의 One-Class SVM 머신러닝을 통해 학습했고, 머신러닝을 개선하기 위해 처음 입력되는 5개의 데이터를 K-S 검정을 통해 이상치를 제거했다. 이 방법으로 침입자를 정상 사용자로 잘못 판단되는 오류율인 FAR은 0.21, 정상 사용자가 침입자로 잘못 판단되는 오류율인 FRR은 0.04 결과를 얻었다.

3.2 A-RBA 평가

RBA 단계에서 적합한 머신러닝은 앞서 설명한 것과 같이 지도학습이므로 대표적인 지도학습 방법인 KNN, 로지스틱 회귀, SVM을 각가 사용하여 성능을 평가하였다. 표 4에서 보듯이, KNN의 모든 지표가 모두 97% 이상으로 가장 정확한 판단 모델이었다. 다음으로 로지스틱 회귀는 정확도 90.8%, 재현율 99.3%, 정밀도 84.6%, F1 Score는 91.3% 그리고 교차 검증 정확도 평균이 93.6%로 정밀도가 다소 떨어지지만 두 번째로 좋은 성능을 보였다. 마지막 SVM 모델의 경우, 정밀도가 98.5%, 교차 검증 정확도 평균이 93.8%로 높은 지표를 가졌지만, 정확도와 F1 Score에서 80% 미만, 재현율은 53.2%로 셋 중에 가장 낮게 평가되었다. 그 이유는 SVM 알고리즘 경우 결과의 과대 적합과 과소 적합을 피하면서 하이퍼 파라미터 변수인 C와 Gamma값을 적절히 선택해 주어야 하는 데, 제안하는 시스템에서는 선택의 어려움이 있기 때문에 낮은 평가 수치를 기록하였다. 따라서 A-RBA 머신러닝 알고리즘은 KNN 알고리즘이 가장 안정적이고 제안하는 시스템에 적합하다고 판단된다.

표 4 A-RBA 머신러닝 알고리즘 성능평가

Table 4 The perfomance evaluation for candiates machine learning algorithm of A-RBA stage

Machine Learning	Accuracy	Recall	Precision	F1-Score	CVAA
KNN	97.5%	98.5%	98.3%	98.1%	99.2%
Logistic Regression	90.8%	99.3%	84.6%	91.3%	93.6%
SVM	72.3%	53.2%	98.5%	76.2%	93.8%

3. 결 론

본 논문에서는 사용자 인증 시 별도의 인증과정 없이 사용자의 패스워드 입력 패턴과 시 공간, 환경정보에서 추출한 7가지의 요소를 이용하여 단일인증 방식의 편리성과 다중인증 방식의 보안성을 모두 갖춘 키스트로크 다이나믹스 및 적응형 위험 기반 인증방식을 활용한 사용자 인증 시스템 구현하였다. 본 연구의 KDA 단계에서는 패스워드 입력 패턴을 분석하여 로그인 시도자가 타 사용자가 아닌지 판단하였다. 웹 환경을 반영하기 위해, 적은 데이터만으로 수행할 수 있도록 데이터셋의 양을 10개로 구성하였고, 비지도학습으로 머신러닝 과정을 진행하였다. A-RBA 단계는 로그인 시도자의 시공간, 환경정보를 머신러닝으로 분석 및 판단하는 기법으로, 실제 상황을 적용하기 위해 중형 도시의 평범한 사무직과 대학생 등과 같은 다양한 행동 시나리오를 만들어 가상 데이터셋을 구성하였다. 이 방식으로 제작된 데이터셋을 사용하여 지도학습 방식의 머신러닝 알고리즘을 대상으로 비교 분석하여 성능평가를 수행하였다. 그 결과, 머신러닝의 모든 평가지표가 97% 이상 판단하였다. 제안하는 시스템은 사용자의 편의성을 잘 살리고, 날로 부상하는 해킹 공격을 극복할 수 있는 좋은 시

스템이 될 것이다. 현재는 가상 데이터셋을 사용할 수밖에 없어 현실 적용에는 다소 어려운 점이 있다. 추가적으로 다양한 접속 시도에 대한 데이터셋을 마련한다면 인증의 정확도가 더 높아질 것으로 예상된다. 또한, 현재의 시스템은 PC 에서만 적용이 가능하지만 모바일에서도 적용할 수 있도록 한다면 사람들의 사용성이 많이 증가할 것으로 기대한다.

References

[1] Xinran Wang, Tadayoshi Kohno and Bob Blakley, "Polymorphism as a Defense for Automated Attack of Websites," in Int. Conf. on Appl. Cryptography and Netw. Secur., pp. 513-530, 2014.

[2] Amanda Goedde, "Credential Stuffing in the Media Industry," Akamai, vol. 6, Jul. 2020. [Online]. Available: https://www.akamai.com/us/en/multimedia/documents/state-of-the-internet/soti-security-credential-stuffing-in-the-media-industry-report-2020.pdf

[3] J.-H. Ki, "The Past and Present of Authentication Technology," ITFIND, pp. 13-22, Sep. 2017.

[4] Aleksandr Ometov, et al. "Multi-Factor Authentication: A Survey," *Cryptography*, vol. 2, no. 1, pp. 1-31, Jan. 2018.

[5] Stephan Wiefling and Luigi Lo Iacono, "Is This Really You? An Empirical Study on Risk-Based Authentication Applied in the Wild," IFIP Adv. in Inf. and Commun. Technol., vol. 562. pp. 134-148, 2019.

[6] Stephan Wiefling, Markus Dürmuth and Luigi Lo Iacono, "More Than Just Good Passwords? A Study on Usability and Security Perceptions of Risk-based Authentication," 2020, arXiv:2010.00339.

[7] Jonghyun Lee, "Exploring the prediction model for middle school low-performing students ratio in mathematics using machine learning," Ph.D. dissertation, Youngnam University, Daegu, Korea, 2020.

[8] Yunhye Oh, "Comparative experiment of Logistic Regression and Machine Learning Performance of Support Vector Machines," M.S. thesis, Kookmin University, Seoul, Korea, 2019.

[9] Jiacang Ho and Dae-Ki Kang, "Sequence Alignment with Dynamic Divisor Generation for Keystroke Dynamics Based User Authentication," J. of Sensors, vol. 2015, pp. 1-14, 2015.

[10] Nataasha Raul, Royston D'mello and Mander Bhalerao, "Keystroke Dynamics Authentication Using Small Datasets," Commun. in Comput. and Inf. Sci., vol. 939, pp. 89-96, 2019.

[11] Pilseong Kang and Seongjun Cho, "A Study on User Authentication based on Keystroke Dynamics of Long and Free Texts," *IE interface*, vol. 25, no. 3, pp. 290-299, 2012.

[12] Mariusz Sepczuk and Zbigniew Kotulski, "A new risk-based authentication management model oriented on user's experience," *Comput. & Secur.*, vol. 73, pp. 17-33, 2018.

[13] Ginam Park. "Network intrusion detection system using machine learning algorithm," M.S. thesis, Sungkyunkwan University, Seoul, Korea, 2019.

저자소개

신지안 (Ji-Ahn Shin)

2015~2020년 상명대학교 정보보안공학과 재학(학사)
주관심분야: 정보보안, AI
E-mail: lanta4825@naver.com

이상협 (Sang-Hyeop Lee)

2015~2020년 상명대학교 정보보안공학과 재학(학사)
주관심분야: 정보보안, AI, 소프트웨어개발
E-mail: thffkans3@naver.com

이승현 (Seung-Hyeon Lee)

2015~2020년 상명대학교 정보보안공학과 재학(학사)
주관심분야: 정보보안
E-mail: ztrdutr@gmail.com

이일현 (Il-Hyn Lee)

2015~2020년 상명대학교 정보보안공학과 재학(학사)
주관심분야: 정보보안, AI, 소프트웨어개발
E-mail: odyssey1297@naver.com

이광재 (Kwangjae Lee)

2014년 고려대학교 전자컴퓨터공학과 졸업(공박). 2012~2017년 전자부품연구원 정보통신미디어본부 연구원. 2017~현재 상명대학교 정보보안공학과 조교수.
E-mail: begleam@smu.ac.kr